Presented by :
Dhruv Baweja (24070126055)
Chahat Patel (24070126047)

DevSecOps Agentic PoC

Autonomous Vulnerability Remediation Multi-Agent AI Workflow

Introduction

- Modern software development and cybersecurity operations face unprecedented scaling challenges as digital infrastructures expand and deployment cadences accelerate to meet market demands.
- Organizations worldwide are under intense pressure to push features into production faster, yet they simultaneously confront a rapidly evolving threat landscape characterized by sophisticated cyber vulnerabilities.
- Traditional security scanning tools and legacy workflows fail to keep pace, creating a severe operational bottleneck that leaves engineering teams trapped in endless cycles of alert fatigue, manual log analysis, and high-friction remediation processes.

To solve this critical industry inefficiency, a domain-specific Agentic AI Proof of Concept (PoC) dedicated to autonomous vulnerability triage and secure patch generation is proposed:

- By shifting away from passive notification scripts toward an active, multi-agent orchestration framework comprising specialized planner, research, coding, and critic agents, enterprises can fully automate the DevSecOps lifecycle.
- This intelligent system bridges the historic divide between rapid software delivery and uncompromising security compliance, ensuring that codebases remain resilient, clean, and audit-ready with minimal human overhead.

Problem Statement

ALERT FATIGUE & SCANNER NOISE

- Modern static and dynamic application security testing tools flood engineering teams with hundreds of low-context alerts on a daily basis.
- Security personnel and developers are constantly overwhelmed by high false-positive rates that mask genuine, exploitable system threats.
- Engineering talent wastes precious hours sorting through non-actionable warnings instead of focusing on core product feature delivery.

MANUAL TRIAGING BOTTLENECKS

- Manually cross-referencing external CVE databases, understanding exploit vectors, and determining file-level impact takes over 35 minutes per alert.
- Engineers frequently lack immediate codebase context during security reviews, leading to sluggish and highly inconsistent vulnerability remediation cycles.
- Security backlogs compound continuously over time, delaying critical software release milestones and exposing organizations to severe compliance risks.

CODE REGRESSION & PATCH RISKS

- Manual code fixes written hastily under pressure often introduce subtle syntax bugs, logic errors, or unexpected application side effects.
- The absence of automated pre-patch unit testing dramatically increases the likelihood of critical application regressions in production.
- Fragmented security practices across disparate development squads result in recurrent, predictable vulnerability patterns across enterprise repositories.

Solutions

Solution 01

Multi-Agent Task Orchestration & Context Analysis

- Deploys an advanced Planner Agent to ingest raw security scanner dumps, decompose complex reports, and structure an optimal task execution graph.
- Integrates a specialized Research Agent to cross-reference global threat intelligence databases while inspecting granular file-level code context.
- Automatically filters out false positives by evaluating whether a reported vulnerability is actively exploitable within the specific application architecture.

Solution 02

Autonomous Secure Code Refactoring & Patch Generation

- Employs a Software Development Agent to programmatically rewrite vulnerable code patterns — such as transforming unsafe string interpolations into secure parameterized queries.
- Eliminates human error during high-urgency security hotfixes by applying mathematically sound syntax refactoring standards across affected files.
- Generates clean, standardized code modifications tailored specifically to the host repository's programming language and coding style guidelines.

Solution 03

Automated Static Validation & Governance Gatekeeping

- Implements a rigorous Critic Agent to execute static code analysis and run simulated unit test suites directly against newly generated patches.
- Acts as an autonomous quality assurance gatekeeper, verifying safety confidence scores before presenting changes for human review.
- Provides strict human-in-the-loop governance backed by complete, audit-ready Pull Request summaries and transparent reasoning trails.

Architectural Advantages

Context-Aware Intelligence

Traditional tools rely on rigid, brittle regex patterns that trigger endless false positives. Our multi-agent architecture utilizes deep codebase context, analyzing variable scopes, dependency trees, and actual execution flows to evaluate real-world exploitability with surgical precision.

Active Self-Correcting Feedback Loops

Unlike basic linear scripts that fail outright upon encountering a syntax anomaly, our framework establishes an active iterative loop.
If the Critic Agent detects a regression or test failure, it dynamically routes the code back to the Developer Agent for automated re-patching.

Secure On-Premise Local Execution Capability

Engineered specifically for data-sensitive enterprises, the solution runs seamlessly on Python and Streamlit with full compatibility for open-source local models via Ollama.
This ensures complete data privacy and eliminates reliance on expensive paid external API endpoints.

Conclusion

The successful integration of Agentic AI into software development and cybersecurity permanently resolves the historic friction between rapid product delivery and rigorous security compliance. By orchestrating specialized planner, research, coding, and critic agents into a cohesive workflow, engineering teams can
eliminate alert fatigue, guarantee flawless patch validation, and scale their security operations effortlessly.

Core Takeaways & Future Outlook:

- **Autonomous Reliability:** Multi-agent collaboration proves capable of executing complex, multi-step engineering tasks with minimal human intervention.
- **Governance & Control:** Structured human-in-the-loop validation ensures absolute safety while maximizing developer velocity and innovation output.
- **Scalable CI/CD Integration:** This proof of concept establishes a robust foundation for future webhooks that will automatically open secure pull requests the moment a security vulnerability is scanned.

Thank You